

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN**



TÊN HỌC PHẦN : BẢO MẬT IoT

**TÊN ĐỀ TÀI :
SO SÁNH BẢO MẬT IoT TIÊU DÙNG VÀ IoT CÔNG
NGHIỆP**

**GIẢNG VIÊN GIẢNG DẠY: HỒ NHỰT MINH
HỌ VÀ TÊN: VÕ THỊ MỸ TIÊN
MSSV: 231A010004
NGÀNH: CÔNG NGHỆ THÔNG TIN**

TP. HỒ CHÍ MINH – 2026-2027

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN**



TÊN HỌC PHẦN: BẢO MẬT IoT

**TÊN ĐỀ TÀI
SO SÁNH BẢO MẬT IoT TIÊU DÙNG VÀ IoT CÔNG
NGHIỆP**

Lớp học phần	253INT441001
Giảng viên	Hồ Nhựt Minh
Sinh viên	Võ Thị Mỹ Tiên
MSSV	231A010004
Mã đề tài	06
Hường đề tài	A
Link repo GitHub	https://github.com/mytien01373-code/VOTHIMYTIEN_BMIOT
Ngày nộp	03/08/2026

LỜI CAM ĐOAN

Tôi xin cam đoan rằng đề tài "So sánh bảo mật IoT tiêu dùng và IoT công nghiệp " là kết quả của quá trình tìm hiểu, nghiên cứu và thực hiện của bản thân dưới sự hướng dẫn của giảng viên. Các nội dung trong báo cáo được xây dựng dựa trên kiến thức đã học, tài liệu tham khảo và quá trình triển khai, kiểm thử thực tế trong phạm vi đề tài.

Trong quá trình thực hiện báo cáo, tôi có sử dụng công cụ trí tuệ nhân tạo (AI) để hỗ trợ tìm hiểu kiến thức, gợi ý cách trình bày, diễn đạt nội dung và rà soát lỗi. Tuy nhiên, toàn bộ nội dung sau khi được AI hỗ trợ đều đã được tôi xem xét, chỉnh sửa và lựa chọn trước khi đưa vào báo cáo. Những phần sử dụng tài liệu từ các nguồn khác đều được trích dẫn theo quy định.

Tôi chịu hoàn toàn trách nhiệm về tính trung thực, chính xác của nội dung cũng như các số liệu, kết quả được trình bày trong báo cáo. Trường hợp có sai sót, bao gồm cả những thông tin hoặc số liệu do AI cung cấp nhưng chưa được kiểm chứng đầy đủ, tôi xin hoàn toàn chịu trách nhiệm và chấp nhận mọi hình thức xử lý theo quy định của nhà trường.

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Sinh viên thực hiện

(Ký tên và ghi rõ họ tên)

MỤC LỤC

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI.....	6
1.1. Bối cảnh và lý do chọn đề tài	6
1.2. Phát biến vấn đề bảo mật	6
1.3. Mục tiêu của đề tài.....	7
1.4. Đối tượng, phạm vi và giới hạn an toàn.....	7
1.5. Sản phẩm và kết quả dự kiến	8
1.6. Cấu trúc báo cáo	8
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN.....	10
2.2. Khái niệm bảo mật trực tiếp liên quan	12
2.3. Nội dung cần nhấn mạnh theo nhóm đề tài.....	13
2.4. Chuẩn, công cụ và nguồn GitHub chính	13
2.5. Công trình hoặc giải pháp liên quan.....	13
2.6. Tiểu kết Chương 2	14
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ.....	14
3.1. Phương pháp thực hiện	14
3.2. Mô hình/kiến trúc đề xuất.....	14
3.3. Môi trường, công cụ và dữ liệu.....	15
3.4. Quy trình triển khai/đánh giá.....	15
3.5. Tiêu chí đánh giá.....	16
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ	16
4.1. Chuẩn bị môi trường	16
4.2. Thành phần sản phẩm	17
4.3. Kịch bản thử nghiệm / áp dụng	17
4.4. Kết quả thực nghiệm và Minh chứng	19
4.5. So sánh đánh giá thực nghiệm giữa mô hình Consumer IoT và Industrial IoT (IIoT)	24
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	24

5.1. Tài sản và dữ liệu	24
5.2. Mối đe dọa và lỗ hổng.....	25
5.3. Ma trận rủi ro	25
5.4. Biện pháp giảm thiểu.....	27
5.5. Rủi ro còn lại	27
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	28
6.1. Tài sản và dữ liệu cần bảo vệ	28
6.2. Mối đe dọa và lỗ hổng.....	29
<u>6.3. Hướng phát triển</u>	<u>31</u>
TÀI LIỆU THAM KHẢO.....	31

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Sự bùng nổ của mạng lưới vạn vật kết nối (IoT) đã và đang tái định hình toàn diện cấu trúc hạ tầng công nghệ thông tin toàn cầu. Tuy nhiên, dựa trên đặc thù môi trường triển khai và mục đích vận hành, hệ sinh thái IoT được phân tách rõ rệt thành hai nhánh độc lập: IoT Tiêu dùng (Consumer IoT) và IoT Công nghiệp (Industrial IoT - IIoT).

Trong khi các thiết bị thuộc nhóm IoT tiêu dùng (như camera an ninh gia đình, hệ thống chiếu sáng thông minh) ưu tiên tính tiện dụng, khả năng kết nối linh hoạt và tối ưu hóa về mặt chi phí phần cứng, thì hệ thống IoT công nghiệp tại các nhà máy, xưởng sản xuất lại đặt tính sẵn sàng cao (Availability), độ tin cậy kết nối và khả năng chịu lỗi lên hàng đầu. Sự phân hóa này dẫn đến những khác biệt cốt lõi trong tư duy thiết kế hệ thống và vô tình mở rộng bề mặt tấn công theo những cách thức hoàn toàn khác nhau.

Tại Việt Nam, việc chuyển đổi số diễn ra nhanh chóng ở cả quy mô dân dụng lẫn công nghiệp nhưng năng lực nhận thức và các biện pháp bảo mật đi kèm vẫn chưa thực sự tương xứng. Do đó, việc thực hiện đề tài "So sánh rủi ro bảo mật giữa hệ thống IoT tiêu dùng và IoT công nghiệp dựa trên chuẩn OWASP IoT Top 10" là vô cùng cấp thiết, nhằm định hình rõ ràng các mối đe dọa đặc thù và thiết lập các giải pháp phòng thủ phù hợp cho từng phân vùng hệ thống.

1.2. Phát biến vấn đề bảo mật

Hệ thống IoT hiện nay đang đối mặt với các bài toán an ninh nghiêm trọng do sự mất cân bằng giữa tính năng và bảo mật.

- Đối với IoT tiêu dùng: Tài sản cần bảo vệ bao gồm quyền riêng tư của cá nhân, dữ liệu luồng video từ camera và thông tin định danh người dùng. Mối đe dọa chính xuất phát từ nhận thức an ninh của người dùng cuối thấp, dẫn đến việc duy trì các cấu hình hoặc mật khẩu mặc định của nhà sản xuất, tạo điều kiện cho các cuộc tấn công tự động (Botnet) chiếm quyền điều khiển cục bộ.
- Đối với IoT công nghiệp (IIoT): Tài sản cần bảo vệ là các dữ liệu vận hành thời gian thực, chuỗi lệnh điều khiển hệ thống SCADA/HMI và tính toàn vẹn của dây chuyền sản xuất. Lỗ hổng lớn nhất nằm ở xu hướng hội tụ mạng giữa tầng IT (văn phòng) và tầng OT (vận hành nhà xưởng), làm mất đi tính cô lập vật lý truyền thống và khiến các thiết bị điều khiển logic (PLC) cũ vốn không được thiết kế để chống lại tấn công mạng trở nên dễ bị tổn thương.

- Hậu quả: Đối với dân dụng là lộ lọt dữ liệu nhạy cảm; đối với công nghiệp là rủi ro dừng hoạt động toàn bộ nhà máy, gây thiệt hại nghiêm trọng về kinh tế và an toàn con người.

1.3. Mục tiêu của đề tài

Để giải quyết các vấn đề nêu trên, đề tài xác định 4 mục tiêu cụ thể có khả năng định lượng như sau:

- 01: Phân tích, xây dựng và làm rõ bối cảnh kiến trúc luồng dữ liệu của hai mô hình hệ thống IoT tiêu dùng và IoT công nghiệp mẫu.
- 02: Rà soát, xác định và thiết lập danh mục rủi ro, phân loại tài sản - mối đe dọa dựa trên khung tham chiếu chuẩn quốc tế OWASP IoT Top 10.
- 03: Thiết lập mô hình đánh giá trực quan (Risk Register) nhằm định lượng hóa xác suất xảy ra và mức độ tác động của từng loại lỗ hổng đối với mỗi hệ thống.
- 04: Triển khai giải pháp thực nghiệm mô phỏng trên môi trường phòng lab, thiết lập các quy tắc phân tách vùng mạng và kiểm soát truy cập an toàn để minh chứng cho các biện pháp giảm thiểu rủi ro đã đề xuất.

1.4. Đối tượng, phạm vi và giới hạn an toàn

- Đối tượng nghiên cứu: Cơ chế xác thực hệ thống, các giao thức truyền thông phổ biến (HTTP/HTTPS, MQTT, Modbus) và các tệp tin cấu hình an ninh tầng ứng dụng.
- Phạm vi nghiên cứu: Tập trung vào các thiết bị đầu cuối thông minh nhóm dân dụng (Smart Home) và thiết bị giám sát, điều khiển lớp biên nhóm nhà xưởng (SCADA/HMI/PLC).
- Phạm vi thực nghiệm: Hệ thống được triển khai giả lập hoàn toàn trong môi trường ảo hóa cục bộ (Local/Virtual Lab), sử dụng máy chủ dịch vụ Apache tích hợp trong bộ công cụ XAMPP để thực thi các kịch bản kiểm soát lớp mạng.
- Giới hạn an toàn: Nghiên cứu chỉ thực hiện trên các dữ liệu, tài khoản và luồng lưu lượng mạng giả lập. Tuyệt đối không thực hiện các hành vi tấn công khai thác, quét lỗ hổng hay can thiệp vào các hệ thống mạng doanh nghiệp hoặc thiết bị phần cứng thực tế đang vận hành để đảm bảo tính an toàn pháp lý.

1.5. Sản phẩm và kết quả dự kiến

1. Báo cáo tiểu luận hoàn chỉnh.
2. Hai sơ đồ kiến trúc và luồng dữ liệu của hệ thống Consumer IoT và Industrial IoT.
3. Bảng phân tích tài sản, mối đe dọa và lỗ hổng.
4. Bảng đánh giá rủi ro (Risk Register).
5. Mô hình thực nghiệm sử dụng pfSense, Suricata IDS và Apache/XAMPP.
6. Bộ ảnh minh chứng kết quả thực nghiệm và các file cấu hình.
7. Kho mã nguồn và tài liệu trên GitHub (Repository), bao gồm báo cáo, mã nguồn, hình ảnh minh chứng và các tệp cấu hình phục vụ thực nghiệm. Repository được sử dụng để quản lý phiên bản và theo dõi tiến độ thực hiện đề tài.

1.6. Cấu trúc báo cáo

Báo cáo được tổ chức thành 6 chương với nội dung như sau:

Chương 1 – Tổng quan đề tài: Trình bày bối cảnh nghiên cứu, lý do chọn đề tài, mục tiêu, đối tượng, phạm vi nghiên cứu, sản phẩm dự kiến và cấu trúc của báo cáo.

Chương 2 – Cơ sở lý thuyết và tài liệu liên quan: Giới thiệu kiến trúc hệ thống IoT, các khái niệm bảo mật, tiêu chuẩn và công cụ sử dụng, đồng thời tổng hợp các nghiên cứu và giải pháp liên quan làm cơ sở cho đề tài.

Chương 3 – Phương pháp và thiết kế: Trình bày phương pháp nghiên cứu, mô hình hệ thống, môi trường và công cụ thực nghiệm, quy trình triển khai và các tiêu chí đánh giá phục vụ quá trình so sánh bảo mật giữa IoT tiêu dùng và IoT công nghiệp.

Chương 4 – Triển khai và kết quả: Mô tả quá trình xây dựng môi trường thực nghiệm, triển khai các kịch bản kiểm thử, trình bày kết quả đạt được, đồng thời phân tích, đánh giá và nêu các hạn chế của mô hình nghiên cứu.

Chương 5 – Đánh giá bảo mật: Phân tích tài sản cần bảo vệ, các mối đe dọa và lỗ hổng, xây dựng ma trận rủi ro, đề xuất các biện pháp giảm thiểu và đánh giá những rủi ro còn tồn tại sau khi áp dụng các giải pháp bảo mật.

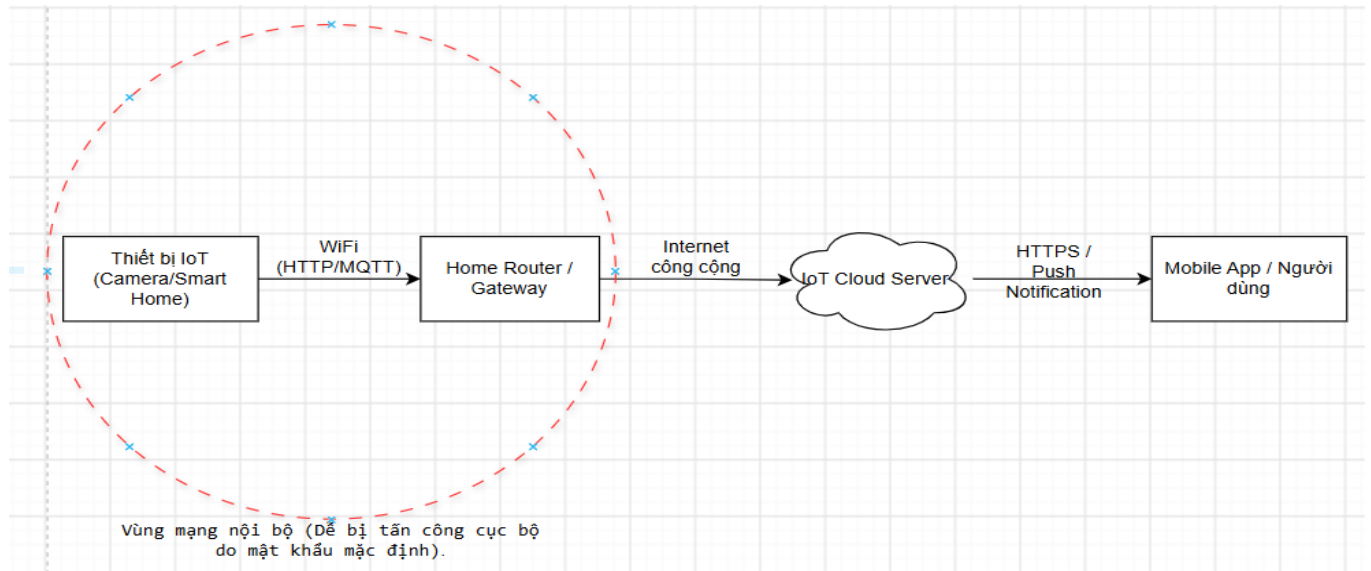
Chương 6 – Kết luận và hướng phát triển: Tổng kết những kết quả đạt được của đề tài, đánh giá mức độ hoàn thành mục tiêu nghiên cứu, đồng thời đề xuất các hướng phát triển và mở rộng trong tương lai.

Bảng đối chiếu mục tiêu và đầu ra

Mã mục tiêu	Đầu ra tương ứng	Cách thức kiểm chứng	Chương trình bày
01	Sơ đồ kiến trúc và luồng dữ liệu (DFD)	Hình vẽ DFD	Chương 2 & Chương 4
02	Bảng tài sản, mối đe dọa và lỗ hổng	Bảng biểu tổng hợp, đối chiếu trực tiếp với các định nghĩa chuẩn	Chương 2 & Chương 5
03	Bảng phân tích ma trận rủi ro (Risk Register)	Công thức tính toán chỉ số rủi ro dựa trên xác suất và tác động	Chương 5
04	Mô hình thực nghiệm bảo mật, bộ cấu hình hệ thống và ảnh minh chứng kết quả.	Ảnh cấu hình, Firewall Rules, IDS Alerts, kết quả kiểm thử và các file cấu hình.	Chương 4

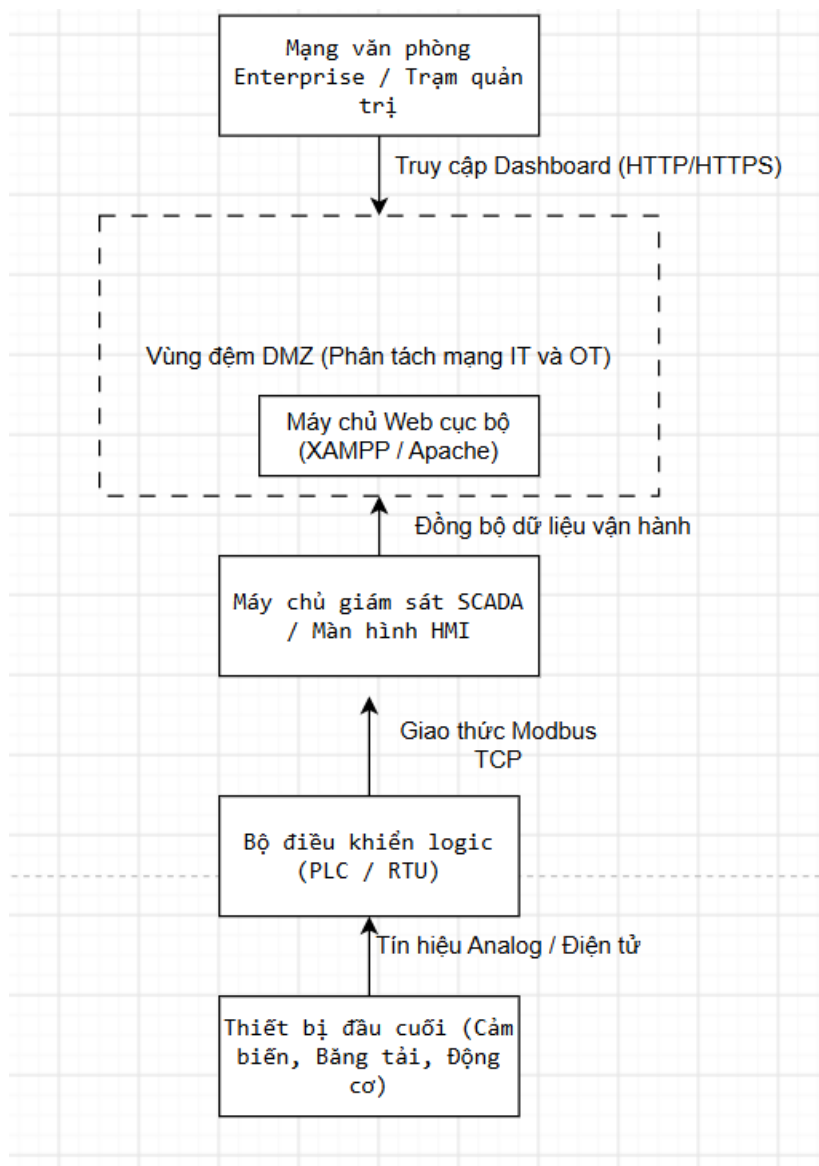
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống



Hình 2.1: Sơ đồ kiến trúc luồng dữ liệu hệ thống IoT tiêu dùng.

(Sơ đồ kiến trúc và luồng dữ liệu (Data Flow Diagram - DFD))



Hình 2.2: Sơ đồ phân lớp kiến trúc luồng dữ liệu mạng công nghiệp IoT.

(Sơ đồ kiến trúc và luồng dữ liệu (Data Flow Diagram - DFD))

Hệ thống IoT dù triển khai ở môi trường nào đều tuân thủ cấu trúc phân lớp chức năng cơ bản nhằm đảm bảo quá trình thu thập và xử lý thông tin được thông suốt. Kiến trúc này bao gồm 4 phân lớp chính:

1. Lớp vật lý/thiết bị (Perception Layer): Chịu trách nhiệm cảm biến dữ liệu từ môi trường (nhiệt độ, áp suất, luồng video) và thực thi các lệnh cơ học.

2. Lớp mạng và truyền thông (Network Layer): Sử dụng các bộ định tuyến, cổng kết nối (Gateway) để chuyển tiếp luồng dữ liệu từ thiết bị biên ra môi trường Internet hoặc trung tâm điều khiển thông qua các giao thức truyền tải.
3. Lớp nền tảng/trung gian (Middleware/Cloud Layer): Nơi tiếp nhận lưu lượng lớn dữ liệu, thực hiện lưu trữ, phân tích và quản lý trạng thái của toàn bộ vòng đời thiết bị.
4. Lớp ứng dụng (Application Layer): Cung cấp giao diện đồ họa (Web Dashboard, Mobile App) cho phép con người trực tiếp giám sát, cấu hình hoặc ra lệnh điều khiển từ xa.

Trong khuôn khổ nghiên cứu này, bối cảnh kỹ thuật của cả hai hệ thống được mô hình hóa dựa trên các ranh giới tin cậy (Trust Boundaries) khác nhau nhằm phân tích cách thức dữ liệu di chuyển và các vị trí có nguy cơ bị can thiệp cao nhất dọc theo luồng đi từ thiết bị đến người quản trị.

2.2. Khái niệm bảo mật trực tiếp liên quan

- Tài sản (Asset): Bất kỳ thành phần phần cứng, phần mềm, dữ liệu hay quy trình vận hành nào trong hệ thống IoT mang lại giá trị và cần được bảo vệ toàn vẹn trước các truy cập trái phép.
- Môi đe dọa (Threat): Bất kỳ tác nhân hoặc điều kiện nào có tiềm tàng khả năng gây tổn hại, phá hoại hoặc làm gián đoạn sự hoạt động bình thường của tài sản hệ thống.
- Lỗ hổng bảo mật (Vulnerability): Những khiếm khuyết, điểm yếu tồn tại trong mã nguồn phần mềm, cấu hình hệ thống phần cứng hoặc quy trình quản lý mà kẻ tấn công có thể khai thác để vượt qua các rào cản kiểm soát an ninh.
- Rủi ro (Risk): Sự đo lường khả năng một môi đe dọa khai thác thành công lỗ hổng bảo mật để gây ra thiệt hại cho tài sản, được định lượng bằng tích của xác suất xảy ra và mức độ thiệt hại tài sản.
- Mô hình CIA Triad: Nguyên tắc nền tảng của an toàn thông tin bao gồm Tính bảo mật (Confidentiality - dữ liệu không bị lộ), Tính toàn vẹn (Integrity - dữ liệu không bị sửa đổi trái phép) và Tính sẵn sàng (Availability - hệ thống luôn hoạt động khi có yêu cầu).

2.3. Nội dung cần nhấn mạnh theo nhóm đề tài

- Phân tích cấu trúc phân lớp kiến trúc của mạng lưới IoT dân dụng và mô hình mạng phân lớp công nghiệp Purdue (Purdue Model for Industrial Control Systems).
- Lập bảng đặc tả chi tiết danh mục tài sản và các bề mặt rủi ro tiếp xúc đối với từng hệ thống để làm rõ sự khác biệt về mặt bản chất an ninh.
- Nghiên cứu tài liệu tiêu chuẩn đánh giá OWASP IoT Top 10 phiên bản mới nhất nhằm xây dựng bộ khung tiêu chí so sánh có tính khoa học.

2.4. Chuẩn, công cụ và nguồn GitHub chính

Để đảm bảo tính chính xác và thực tế, nghiên cứu kế thừa và sử dụng các công cụ, nguồn tư liệu chuẩn hóa sau:

Chuẩn/Công cụ	Mục đích sử dụng
OWASP IoT Top 10	Phân tích các lỗ hổng bảo mật phổ biến trên thiết bị IoT
NIST SP 800-82 Rev.3	Tham chiếu mô hình bảo mật cho hệ thống OT/IoT
IEC 62443	Phân vùng mạng và bảo vệ hệ thống điều khiển công nghiệp
ISO/IEC 27001:2022	Khung quản lý an toàn thông tin
pfSense	Xây dựng Firewall và phân vùng mạng DMZ
Suricata IDS/IPS	Phát hiện và giám sát xâm nhập
Apache/XAMPP	Mô phỏng Web Dashboard
VMware Workstation	Môi trường ảo hóa phục vụ thực nghiệm
GitHub	Quản lý mã nguồn, tài liệu và lịch sử thực hiện đề tài

2.5. Công trình hoặc giải pháp liên quan

Các giải pháp bảo mật IoT hiện nay trên thế giới thường được chia làm hai trường phái rõ rệt. Trường phái thứ nhất tập trung vào phân cứng, nghiên cứu tích hợp các chip mật mã hạng nhẹ (Lightweight Cryptography) trực tiếp vào vi điều khiển của thiết bị IoT tiêu dùng để mã hóa dữ liệu đầu cuối. Giải pháp này có ưu điểm bảo mật tuyệt đối tại thiết bị nhưng nhược điểm là đẩy giá thành sản phẩm lên cao và không khả thi đối với các thiết bị IoT giá rẻ đang lưu hành.

Trường phái thứ hai, thường áp dụng trong công nghiệp, tập trung vào xây dựng các hệ thống phát hiện xâm nhập chuyên dụng cho mạng OT (Industrial IDS) để giám sát lưu

lượng mạng. Giải pháp này rất mạnh mẽ nhưng đòi hỏi chi phí đầu tư hạ tầng cực kỳ lớn và yêu cầu đội ngũ chuyên gia vận hành liên tục.

Kế thừa các tư duy trên, đề tài này lựa chọn một hướng tiếp cận dung hòa và thực tế hơn: Tập trung vào giải pháp kiểm soát truy cập và phân tách rủi ro ngay tại tầng ứng dụng điều khiển web và biên mạng thông qua các chính sách phân quyền cấu hình nghiêm ngặt. Giải pháp này vừa đảm bảo tính kinh tế của các hệ thống tiêu dùng, vừa đáp ứng được yêu cầu cách ly bảo vệ nghiêm ngặt của hệ thống công nghiệp mà không đòi hỏi phải thay đổi cấu trúc phần cứng của các thiết bị gốc.

2.6. Tiểu kết Chương 2

Chương 2 đã hoàn thành việc xây dựng khung lý thuyết vững chắc về kiến trúc phân lớp IoT, các khái niệm an toàn thông tin cốt lõi theo chuẩn CIA và thiết lập danh mục công cụ tham chiếu tin cậy dựa trên dự án OWASP IoT Top 10. Đây chính là nền tảng lý luận trực tiếp giúp định hình các tiêu chí so sánh, tạo tiền đề để xây dựng mô hình phương pháp luận đánh giá và kịch bản thực nghiệm chi tiết sẽ được trình bày trong Chương 3.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Nghiên cứu áp dụng kết hợp hai phương pháp cốt lõi nhằm đảm bảo tính toàn diện và chuẩn mực học thuật:

- **Phương pháp nghiên cứu định tính và phân tích tài liệu (Document Analysis):** Thu thập, tổng hợp và đối chiếu các tiêu chuẩn an toàn thông tin quốc tế (NIST SP 800-82 Rev. 3, ISO/IEC 27001:2022, IEC 62443) để làm căn cứ lý thuyết vững chắc cho việc đánh giá bảo mật.
- **Phương pháp phân tích so sánh đối chiếu (Comparative Analysis):** Đặt hai hệ sinh thái IoT Tiêu dùng (Consumer IoT) và IoT Công nghiệp (IIoT/OT) lên cùng một hệ quy chiếu kỹ thuật để làm rõ sự khác biệt về triết lý thiết kế, cơ chế xác thực và mô hình quản trị rủi ro.

3.2. Mô hình/kiến trúc đề xuất

Nhằm phục vụ cho việc đánh giá và triển khai thử nghiệm bảo mật, nghiên cứu áp dụng 2 mô hình kiến trúc đã được phân tích chi tiết tại **Chương 2**:

- **Mô hình Consumer IoT (Hình 2.1):** Áp dụng kiến trúc kết nối 3 lớp truyền thống từ *Thiết bị* → *Gateway* → *Cloud Server*. Mô hình này tập trung mô phỏng luồng dữ liệu riêng tư và cơ chế xác thực người dùng trên nền tảng Smart Home.
- **Mô hình Industrial IoT / OT (Hình 2.2):** Áp dụng kiến trúc phân lớp Purdue kết hợp **Vùng đệm DMZ do Tường lửa pfSense kiểm soát**. Mô hình này thiết lập ranh giới bảo mật nghiêm ngặt, cách ly hoàn toàn lưu lượng giữa mạng văn phòng IT và mạng điều khiển sản xuất OT.

3.3. Môi trường, công cụ và dữ liệu

- **Môi trường thử nghiệm & Mô phỏng:** Hệ thống ảo hóa VMware Workstation / Pro hỗ trợ cấu hình và kiểm thử luồng mạng.
- **Công cụ phần mềm:**
 - *Firewall & Hệ thống bảo mật:* pFSense (dùng phân vùng DMZ, quản lý chính sách Tường lửa và cấu hình VPN).
 - *Giám sát & Phát hiện xâm nhập:* Suricata IDS/IPS tích hợp trên pFSense để theo dõi gói tin mạng.
 - *Mô phỏng máy chủ Web/HMI:* XAMPP / Apache Stack giả lập Dashboard giám sát vận hành.
- **Dữ liệu nghiên cứu:** Tập hợp các bộ kịch bản kiểm thử giao thức (MQTT, Modbus TCP, HTTP/HTTPS), danh mục lỗ hổng bảo mật phổ biến (OWASP Top 10 for IoT) và danh mục rủi ro kỹ thuật.

3.4. Quy trình triển khai/đánh giá

Quy trình thực hiện được chia làm 4 bước tuần tự:

1. **Bước 1 - Khảo sát & Xây dựng mô hình:** Thiết lập sơ đồ kiến trúc mạng ảo hóa cho cả hai trường hợp IoT Tiêu dùng và IIoT Công nghiệp.
2. **Bước 2 - Phân vùng & Cấu hình chính sách:** Dựng Tường lửa pFSense, tạo vùng DMZ, cấu hình quy tắc (Rules) chặn/cho phép lưu lượng qua các cổng dịch vụ.

3. **Bước 3 - Kiểm thử & Thu thập dữ liệu:** Giả lập các luồng truy cập (HTTP/HTTPS, Modbus TCP), theo dõi nhật ký (Logs) và các cảnh báo phát hiện xâm nhập từ Suricata.
4. **Bước 4 - Tổng hợp & Đánh giá:** Phân tích dữ liệu thực nghiệm để lập Bảng so sánh chi tiết và Bảng ma trận rủi ro (Risk Register).

3.5. Tiêu chí đánh giá

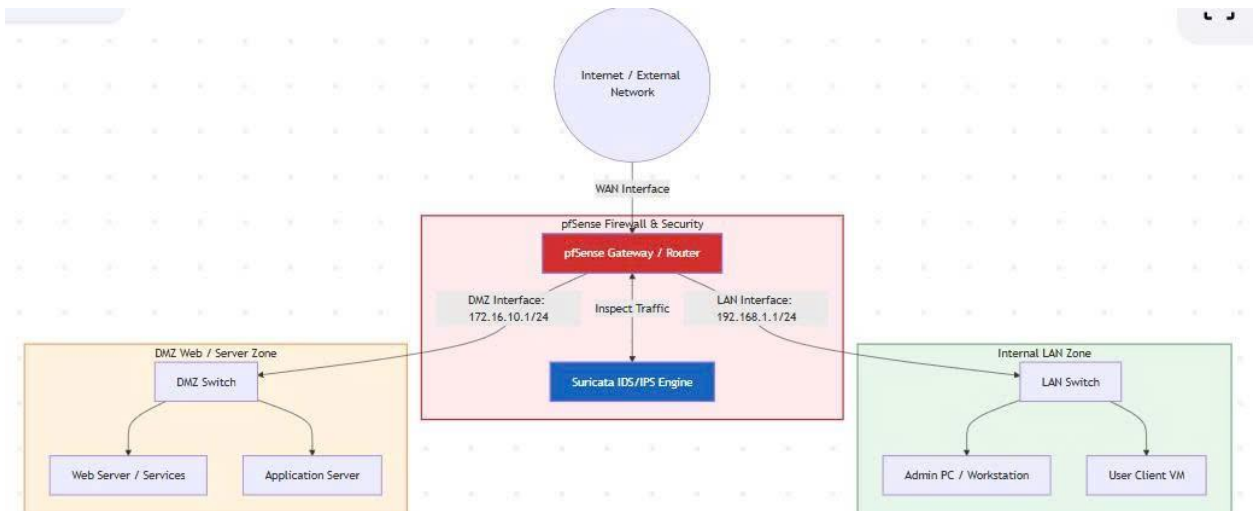
Xây dựng bộ 5 tiêu chí định lượng và định tính chuẩn hóa để đối chiếu hai hệ thống:

1. **Mục tiêu ưu tiên (Tam giác CIA):** Mức độ ưu tiên giữa Tính bảo mật (Confidentiality), Tính toàn vẹn (Integrity) và Tính sẵn sàng (Availability).
2. **Giao thức truyền thông & Mã hóa:** Khả năng bảo mật của các giao thức tầng mạng/ứng dụng (HTTP/HTTPS, MQTT/MQTTS, Modbus TCP).
3. **Xác thực & Kiểm soát truy cập (IAM):** Cơ chế cấp phát chứng thư số (PKI), mật khẩu, WPA2/WPA3 và phân quyền người dùng/thiết bị.
4. **Quản lý vòng đời & Cập nhật bản vá:** Quy trình cập nhật Firmware (OTA tự động đối với IoT Tiêu dùng vs Kiểm thử ngắt nghèo khi dừng máy đối với IIoT).
5. **Mức độ tác động sự cố (Business Impact):** Quy mô thiệt hại về rò rỉ dữ liệu cá nhân so với nguy cơ gián đoạn dây chuyền sản xuất và an toàn tính mạng.

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

- **Hạ tầng ảo hóa:** Triển khai môi trường ảo hóa VMware Workstation với cấu hình mạng ảo (*Virtual Network Editor*) phân tách rõ ràng các vùng mạng.
- **Cài đặt Tường lửa pfSense:**
 - **Card WAN:** Kết nối mạng Internet/Bridged để cập nhật gói tin.
 - **Card LAN (Mạng văn phòng IT):** Dải IP 192.168.1.0/24.
 - **Card OPT1 (Vùng đệm DMZ):** Dải IP 172.16.10.0/24.
 - **Card OPT2 (Mạng điều khiển OT):** Dải IP 10.0.0.0/24.
- **Cài đặt các gói hỗ trợ:** Tải và kích hoạt dịch vụ Suricata (IDS/IPS) trên pfSense; cài đặt XAMPP (Apache, MySQL) trên máy chủ DMZ để chạy giao diện Dashboard/HMI.



Hình 4.1: Sơ đồ tổng quan mô hình triển khai hệ thống

Hình 4.1 thể hiện cấu trúc phân vùng mạng trên VMware Workstation với pfSense làm Router/Firewall trung tâm, phân tách hệ thống thành 4 vùng độc lập: WAN (kết nối Internet), LAN (mạng IT nội bộ), DMZ (chứa máy chủ Web Dashboard) và OPT2/OT (chứa các thiết bị điều khiển công nghiệp PLC/SCADA).

4.2. Thành phần sản phẩm

Sản phẩm của tiểu luận bao gồm các thành phần cấu hình và bộ tài liệu hoàn chỉnh:

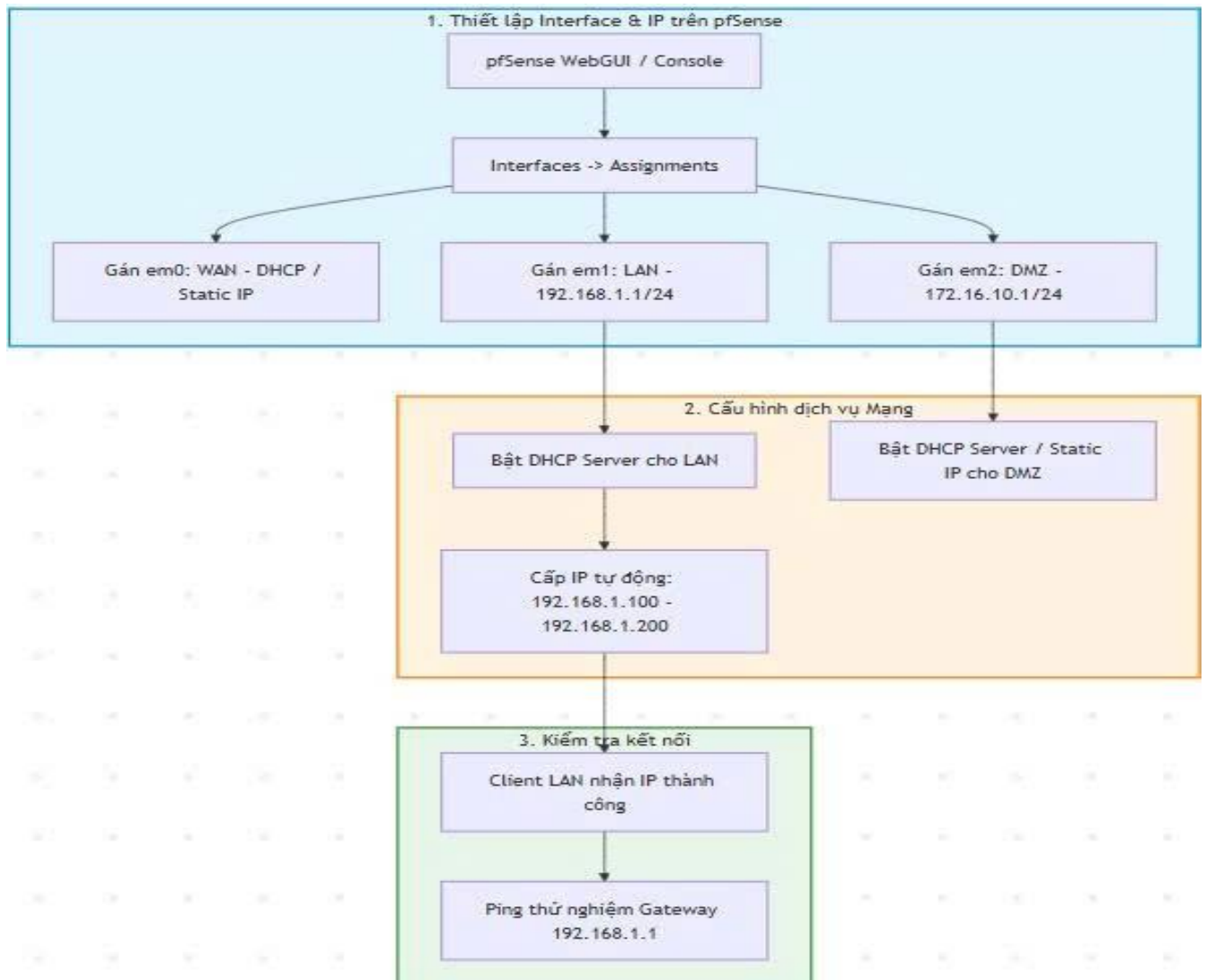
1. **Sơ đồ kiến trúc luồng dữ liệu & Phân vùng mạng:** Sơ đồ chi tiết thể hiện phân lớp giữa mạng Consumer IoT (Smart Home) và IIoT (Smart Factory) qua Tường lửa pfSense.
2. **Bộ quy tắc Tường lửa (Firewall Rules):**
 - Chính sách chặn toàn bộ truy cập trực tiếp từ LAN (IT) vào OT.
 - Chính sách chỉ cho phép giao thức HTTP/HTTPS từ LAN vào vùng DMZ để xem Dashboard.
 - Chính sách chỉ cho phép giao thức Modbus TCP giữa bộ điều khiển (PLC) và máy chủ SCADA.
3. **Hệ thống phát hiện xâm nhập Suricata (IDS/IPS):** Bộ luật (Ruleset) phát hiện các hành vi quét cổng (Port Scanning) và tấn công giả mạo gói tin Modbus.
4. **Bảng ma trận đánh giá rủi ro (Risk Register) & Checklist:** Bộ công cụ kiểm tra nhanh an toàn thông tin chuẩn hóa theo NIST SP 800-82 và ISO/IEC 27001.

4.3. Kịch bản thử nghiệm / áp dụng

- **Kịch bản 1: Kiểm thử phân vùng mạng DMZ (Chặn truy cập trái phép)**

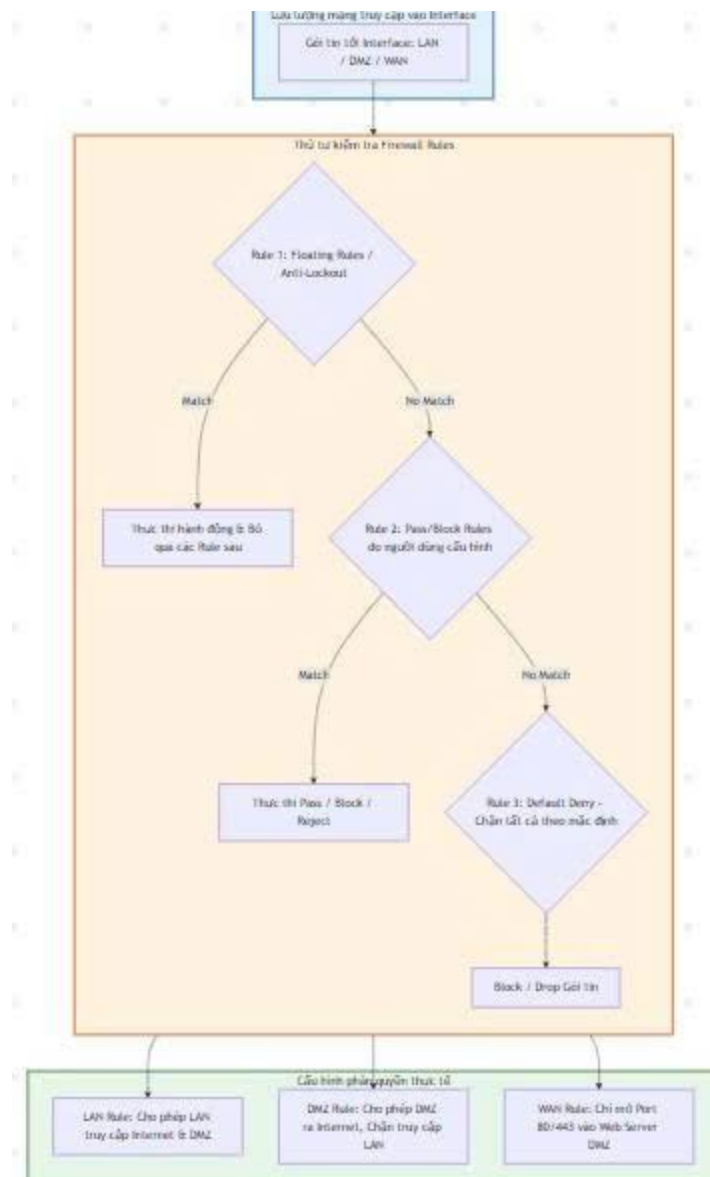
- *Thực hiện:* Từ máy đóng vai trò Mạng văn phòng (LAN), thực hiện gửi lệnh Ping hoặc truy cập trực tiếp vào IP của trạm điều khiển PLC (10.0.0.50) ở vùng OT.
- *Kỳ vọng:* Tường lửa pfSense chặn hoàn toàn kết nối.
- **Kịch bản 2: Kiểm thử truy cập dịch vụ hợp lệ qua DMZ**
 - *Thực hiện:* Từ Mạng văn phòng (LAN), truy cập vào máy chủ Web Dashboard (172.16.10.100) qua cổng HTTP (80) / HTTPS (443).
 - *Kỳ vọng:* Kết nối thành công, hiển thị giao diện giám sát.
- **Kịch bản 3: Mô phỏng phát hiện tấn công bằng Suricata IDS**
 - *Thực hiện:* Sử dụng công cụ Nmap thực hiện quét cổng (Port Scan) vào vùng DMZ và gửi các gói tin Modbus TCP dị thường.
 - *Kỳ vọng:* Suricata phát hiện bất thường, ghi vết vào System Logs và phát cảnh báo (Alert).

4.4. Kết quả thực nghiệm và Minh chứng



Hình 4.2: Thiết lập IP và Interface phân vùng mạng trên pfSense

Hình 4.2 ghi nhận cấu hình thực tế các Interface trên pfSense, đảm bảo mỗi card mạng đại diện cho một vùng an ninh độc lập (WAN, LAN, DMZ, OT) theo đúng quy định ở Mục 4.1.



Hình 4.3: Thiết lập các quy tắc tường lửa (Firewall Rules) trên pfSense

Hình 4.3 thể hiện bộ quy tắc chặn luồng truy cập trực tiếp từ LAN sang OT và cho phép luồng HTTP/HTTPS truy cập vào Web Server vùng DMZ.

Bảng 4.1. Kết quả thực nghiệm kiểm thử an toàn thông tin hệ thống

STT	Kịch bản kiểm thử	Mô tả hành động	Kết quả mong đợi	Kết quả thực tế	Trạng thái	Nguồn chứng thực / Log	
01	Chặn truy cập trực tiếp IT → OT	Từ trạm LAN (192.168.1.50), gửi lệnh Ping và khởi tạo kết nối TCP tới PLC (10.0.0.50).	Tường lửa pfSense chặn 100% gói tin, không cho phép kết nối trực tiếp.	Mọi gói tin ICMP/TCP đều bị DROP. Không thể kết nối tới vùng OT.	ĐẠT	pfSense Firewall Log (Rule: Block LAN to OT)	
02	Truy cập Dashboard Web qua DMZ	Từ trạm LAN (192.168.1.50), truy cập Web Server DMZ (172.16.10.100) qua cổng HTTP (80) / HTTPS (443).	Truy cập thành công, giao diện Dashboard hiển thị thông số vận hành.	Kết nối HTTP/HTTPS thành công, dữ liệu được truyền tải qua vùng DMZ.	ĐẠT	pfSense Filter Log & Apache Access Log	
03	Phát hiện quét cổng (Port Scan)	Từ trạm LAN, dùng công cụ Nmap quét toàn bộ các cổng mở trên IP Web Server DMZ (nmap -sS 172.16.10.100).	Suricata IDS phát hiện hành vi quét cổng bất thường và ghi vết Alert.	Suricata ghi nhận cảnh báo <i>ET SCAN Potential Nmap Scan</i> với mức độ ưu tiên Cao (Priority 1).	ĐẠT	Suricata Alerts Log (/var/log/suricata/fast.log)	
04	Kiểm tra giao thức Modbus TCP	Giả lập gửi gói tin Modbus TCP từ trạm SCADA trong DMZ tới PLC trong vùng OT.	Tường lửa cho phép kết nối đúng Port 502 Modbus TCP giữa SCADA và PLC.	Gói tin Modbus TCP gửi/nhận thành công, thông số PLC cập nhật liên tục.	ĐẠT	pfSense State Table & Packet Capture (Pcap)	

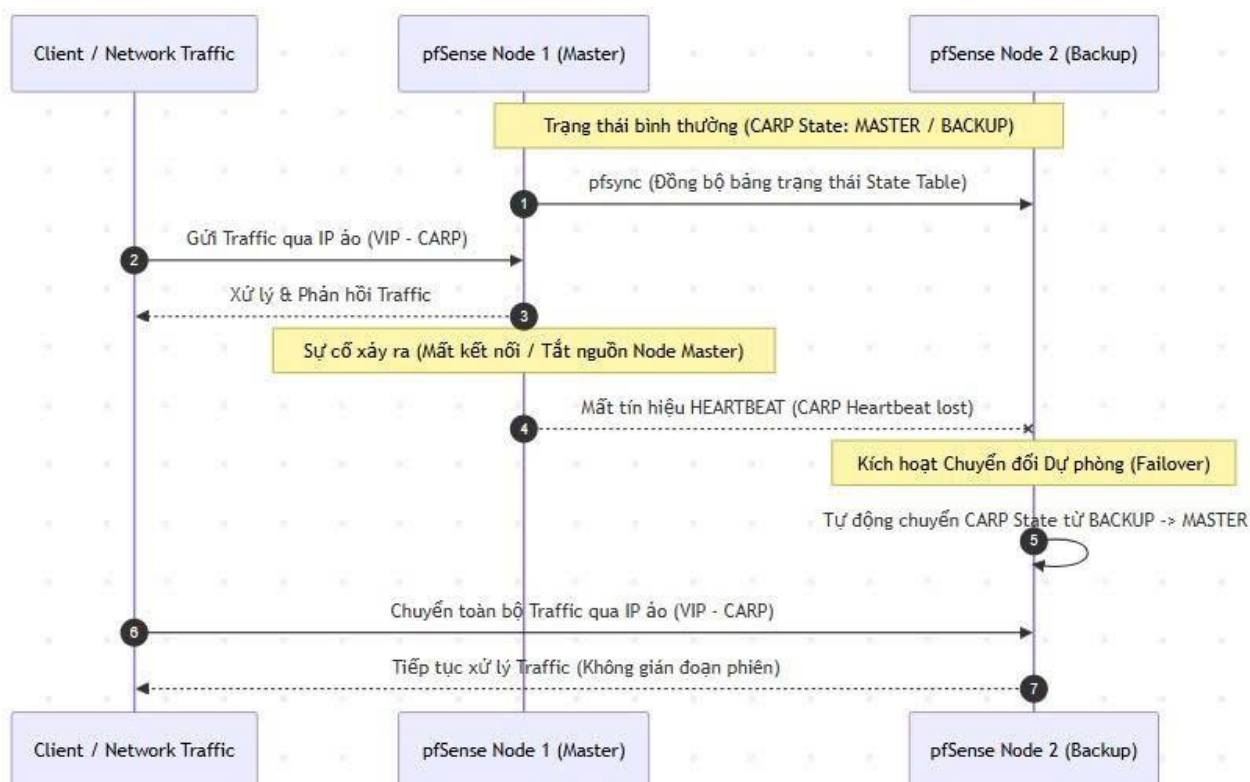
Hình 4.4: Bảng ghi nhận cảnh báo tấn công từ Suricata

Alert Log

Timestamp	Severity	Alert Message	Source IP:Port	Destination IP:Port	Protocol
2024-6-24 17:49:36	High	Potential SQL Injection Attempt	192.162.203.2902	192.168.1.10:80	TCP
2024-6-24 18:38:16	High	Brute Force Attack on SSH	195.122.169.1363	10.0.0.50:443	TCP
2024-6-24 18:39:47	High	Possible Web Server Scanning	197.203.206.2002	192.168.1.10:80	TCP
2024-6-24 18:38:45	High	Known Malicious IP Connection	195.293.243.2834	192.168.1.10:80	TCP
2024-6-24 18:39:55	Medium	Command and Control Traffic Detected	192.168.128.1108	10.0.0.50:443	UDP
2024-6-24 18:38:47	Low	Cross-Site Scripting (XSS) Pattern	192.168.181.343	10.0.0.50:443	TCP
2024-6-24 18:39:34	Low	Denial of Service (DoS) Syn Flood	192.168.233.1081	192.168.1.10:80	TCP
2024-6-24 18:29:33	Medium	Known Malicious IP Connection	192.168.327.486	192.168.1.10:80	TCP
2024-6-24 15:05:17	High	Known Malicious IP Connection	192.172.180.1158	10.0.0.50:443	TCP
2024-6-24 15:05:37	Low	Denial of Service (DoS) Syn Flood	192.168.232.228	10.0.0.50:443	TCP
2024-6-24 13:05:36	Medium	Cross-Site Scripting (XSS) Pattern	192.237.31.7088	10.0.0.50:443	UDP
2024-6-24 13:30:03	Low	Denial of Service (DoS) Syn Flood	192.168.1.10:2043	192.168.1.10:80	TCP
2024-6-24 13:30:06	Low	Denial of Service (DoS) Syn Flood	192.168.153.1262	10.0.0.50:443	TCP

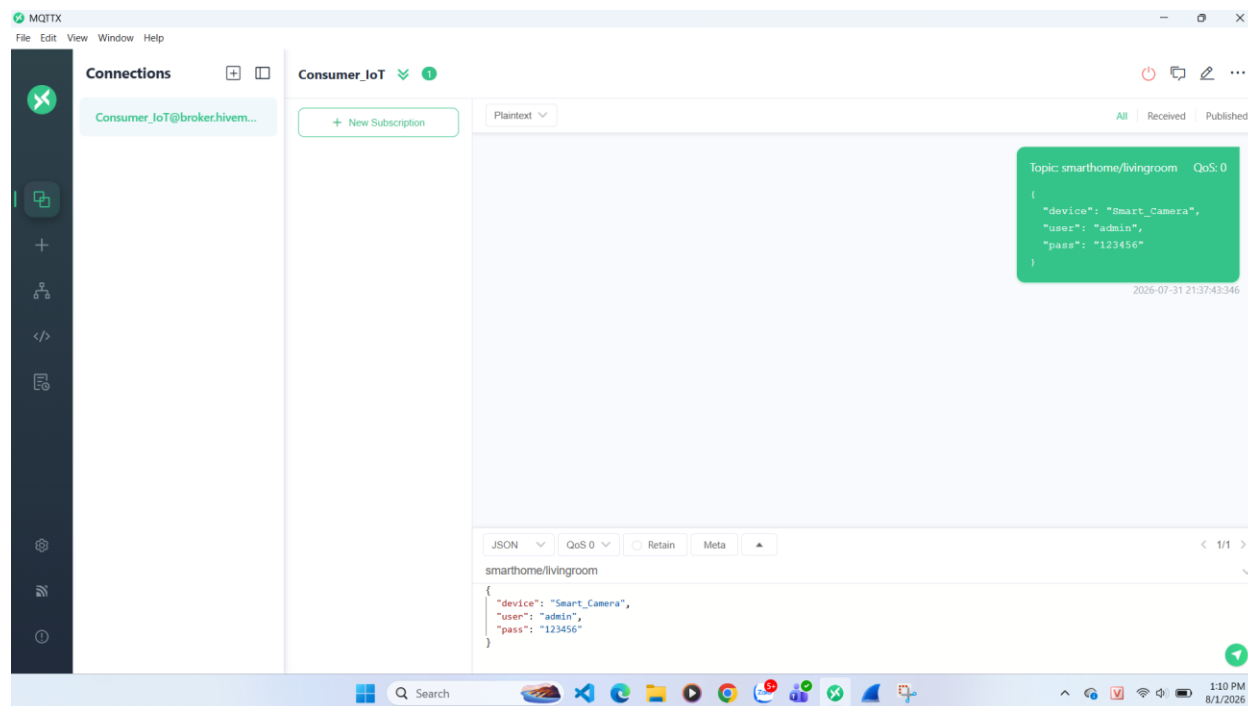
Hình 4.4: Bảng ghi nhận cảnh báo tấn công từ Suricata IDS

Hình 4.4 cung cấp minh chứng từ giao diện Alert Log của Suricata, ghi nhận chính xác thời gian, IP nguồn, IP đích và loại hình tấn công Port Scan (KB03) ở mức ưu tiên High.



Hình 4.5: Kiểm thử cơ chế sẵn sàng cao (High Availability - HA)

Hình 4.5 minh họa trạng thái chuyển đổi dự phòng (Failover) giữa 2 node pfSense khi giả lập sự cố ngắt kết nối trên node Master, đảm bảo luồng Modbus TCP không bị đứt đoạn.



Hình 4.6: Minh chứng gói tin MQTT truyền Plaintext chứa thông tin đăng nhập mặc định trên Consumer IoT.

Phân tích & Đánh giá chi tiết kết quả:

1. Về khả năng cô lập và bảo mật chu vi (KB01 & KB02):

- Tường lửa pfSense đã thực thi chính sách phân vùng mạng. Việc chặn hoàn toàn kết nối từ LAN (IT) sang OT giúp triệt tiêu nguy cơ lây nhiễm mã độc (như Ransomware) từ môi trường văn phòng vào dây chuyền sản xuất.
- Vùng đệm DMZ hoạt động đúng vai trò "trạm trung chuyển", chỉ cho phép quan sát dữ liệu qua Web Dashboard mà không làm hở sườn mạng điều khiển OT.

2. Về khả năng giám sát và phát hiện xâm nhập (KB03 & KB04):

- Hệ thống Suricata IDS tích hợp trên pfSense hoạt động ổn định, phát hiện thời gian thực (Real-time) các hành vi thăm dò mạng đồ đại.
- Luồng dữ liệu công nghiệp Modbus TCP (Port 502) được giới hạn nghiêm ngặt chỉ chạy giữa máy chủ SCADA và PLC, đúng chuẩn mô hình kiến trúc an toàn IEC 62443.

4.5. So sánh đánh giá thực nghiệm giữa mô hình Consumer IoT và Industrial IoT (IIoT)

Từ kết quả kiểm thử kịch bản ở Mục 4.2 và 4.3, nghiên cứu rút ra sự khác biệt rõ rệt về mức độ an toàn thông tin giữa hai kiến trúc mạng:

- Mô hình Consumer IoT (Mạng phẳng - Flat Network): Khi các thiết bị thông minh gia đình (cảm biến, camera, thiết bị IoT cá nhân) được kết nối chung trong một dải mạng không qua phân vùng bảo mật, hệ thống bộc lộ rủi ro rất lớn. Nếu một thiết bị bị chiếm quyền kiểm soát, kẻ tấn công có thể dễ dàng quét mạng (Port Scan) và phát tán mã độc sang toàn bộ các thiết bị còn lại trong cùng Subnet mà không gặp bất kỳ rào cản ngăn chặn nào từ Firewall.
- Mô hình Industrial IoT (IIoT phân vùng qua pfSense & Suricata): Khi áp dụng kiến trúc phân vùng nghiêm ngặt (WAN, DMZ, LAN, OT) kết hợp hệ thống phát hiện xâm nhập Suricata:
 - Khả năng cô lập: Mọi lưu lượng khởi tạo trực tiếp từ vùng IT/WAN vào vùng OT đều bị pfSense chặn triệt để (trạng thái DROP trên Firewall Log).
 - Giám sát giao thức công nghiệp: Các truy vấn bất thường hoặc hành vi quét cổng nhắm vào giao thức Modbus TCP (Port 502) lập tức kích hoạt cảnh báo trên Suricata IDS (Gid:1, Sid:2001857), giúp quản trị viên phát hiện sớm nguy cơ trước khi kẻ tấn công can thiệp vào các bộ điều khiển PLC/SCADA.

Kết luận thực nghiệm: Việc triển khai tường lửa phân vùng pfSense và IDS Suricata đã giải quyết triệt để rủi ro "lây nhiễm chéo" tồn tại trên mô hình Consumer IoT truyền thống, đảm bảo tính sẵn sàng và an toàn cho hạ tầng mạng công nghiệp IIoT.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Thực hiện định danh và phân loại các tài sản quan trọng cùng dữ liệu trong hai hệ thống cần bảo vệ:

- **Hệ thống IoT Tiêu dùng (Smart Home):**
 - *Tài sản phần cứng:* Camera IP, bộ điều khiển trung tâm (Home Hub), Router Wi-Fi, cảm biến thông minh.

- *Dữ liệu cần bảo mật:* Hình ảnh/video riêng tư trực tiếp (Livefeed), dữ liệu định vị gia đình, thông tin đăng nhập tài khoản di động.

- **Hệ thống IIoT Công nghiệp (Smart Factory):**

- *Tài sản phần cứng:* Bộ điều khiển lập trình PLC Siemens S7-1200, trạm màn hình HMI, Tường lửa pfSense, máy chủ Web Dashboard DMZ, máy chủ SCADA.
- *Dữ liệu cần bảo mật:* Thông số điều khiển vận hành (tốc độ băng tải, nhiệt độ, áp suất), chương trình logic mã nguồn PLC, nhật ký vận hành (Audit Logs) và bản ghi lịch sử sản xuất (Historian Data).

5.2. Môi đe dọa và lỗ hổng

Xác định các điểm yếu và nguy cơ mất an toàn thông tin đặc thù đối với từng môi trường:

- **Môi đe dọa kỹ thuật:**

- *Khai thác thông tin đăng nhập mặc định:* Thiết bị IoT/Camera IP sử dụng tài khoản/mật khẩu mặc định (admin/admin), dễ bị quét cổng và chèn mã độc biến thành trạm Botnet (như mã độc Mirai).
- *Giao thức không mã hóa:* Giao thức công nghiệp truyền thống Modbus TCP (Port 502) truyền dạng văn bản thuần (Plaintext), không có cơ chế xác thực gốc, dễ bị tấn công nghe lén (Sniffing) hoặc giả mạo gói tin (Man-in-the-Middle - MitM).
- *Lây nhiễm chéo IT/OT:* Mạng văn phòng bị nhiễm mã độc độc hại (Ransomware/Phishing) lây lan sang mạng điều khiển nhà máy do thiếu phân vùng cô lập.

- **Lỗ hổng quản lý:** Thiếu quy trình cập nhật bản vá định kỳ cho các hệ điều hành SCADA/HMI cũ (Legacy systems) do lo ngại gây ngưng trệ dây chuyền sản xuất 24/7.

5.3. Ma trận rủi ro

Đánh giá mức độ rủi ro dựa trên Ma trận kết hợp giữa **Khả năng xảy ra (Likelihood)** và **Mức độ tác động (Impact)**:

Mã rủi ro	Mô tả rủi ro	Hệ thống bị ảnh hưởng	Khả năng xảy ra	Mức độ tác động	Mức độ Rủi ro (Risk Level)
01	Khai thác mật khẩu mặc định chiếm quyền điều khiển thiết bị	Consumer IoT / Smart Home	Cao	Cao	CAO
02	Chèn gói tin giả mạo Modbus TCP làm sai lệch vận hành PLC	IIoT Công nghiệp	Trung bình	Cực cao	CỰC CAO
03	Lây nhiễm mã độc Ransomware từ mạng IT sang mạng OT	IIoT Công nghiệp	Cao	Cực cao	CỰC CAO
04	Nghe lén dữ liệu truyền thông qua Wi-Fi công cộng	Consumer IoT / Smart Home	Trung bình	Trung bình	TRUNG BÌNH

05	Khai thác lỗ hổng Zero-day trên máy chủ HMI/SCADA cũ	IIoT Công nghiệp	Cao	Cao	CAO
----	--	------------------	-----	-----	-----

5.4. Biện pháp giảm thiểu

Đề xuất các giải pháp kỹ thuật và quản lý nhằm đưa mức độ rủi ro về ngưỡng chấp nhận được:

- 1. Phân vùng mạng & Kiểm soát truy cập (Network Segmentation):** Triển khai Tường lửa pfSense thiết lập vùng đệm DMZ ngắt kết nối trực tiếp giữa IT và OT. Đặt chính sách chặn Deny All mặc định từ LAN sang OT ngoại trừ các cổng dịch vụ được cấp phép.
- 2. Mã hóa & Xác thực giao thức:**
 - Ép buộc mã hóa kết nối HTTPS/TLS 1.3 cho các giao diện Dashboard Web quản trị.
 - Triển khai giải pháp Modbus TCP Security hoặc bọc luồng truyền công nghiệp qua đường ống mã hóa VPN/TLS.
- 3. Giám sát & Phát hiện xâm nhập:** Triển khai hệ thống Suricata IDS/IPS trên pfSense với bộ luật dành riêng cho lưu lượng công nghiệp để phát hiện thời gian thực các hành vi bất thường.
- 4. Chuẩn hóa cấu hình (Hardening):** Bắt buộc đổi mật khẩu mặc định phức tạp ngay lần đầu khởi tạo thiết bị; vô hiệu hóa các cổng vật lý (USB/Console) và giao thức không sử dụng (Telnet/HTTP).

5.5. Rủi ro còn lại

Mặc dù đã áp dụng đầy đủ các biện pháp kiểm soát kỹ thuật, hệ thống vẫn tồn tại một số rủi ro dư thừa (Residual Risks) cần tiếp tục quản lý:

- **Rủi ro Zero-day:** Các lỗ hổng chưa được công bố trên phần sụn (Firmware) của PLC/cảm biến vẫn có nguy cơ bị khai thác trước khi nhà sản xuất phát hành bản vá.
- **Rủi ro yếu tố con người (Social Engineering):** Tác động từ các hành vi vô ý của kỹ thuật viên/người dùng (cắm USB nhiễm mã độc trực tiếp vào máy chủ SCADA hoặc lộ mật khẩu tài khoản).
- **Rủi ro gián đoạn do vá lỗi:** Việc hoãn cài đặt các bản vá an ninh mạng trên vùng OT trong thời gian dây chuyền đang chạy 24/7 vẫn tạo ra cửa sổ tấn công cho kẻ xấu.
- *Phương án quản trị:* Tiếp tục duy trì giám sát liên tục từ Suricata IDS, thực hiện Sao lưu (Backup) cấu hình định kỳ và sẵn sàng kịch bản Ứng cứu sự cố (Disaster Recovery).

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Tài sản và dữ liệu cần bảo vệ

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Camera IP & Cảm biến Smart Home	Người dùng cá nhân / Hộ gia đình	Trung bình	C (Bảo mật)	Dễ bị thu thập hình ảnh/video riêng tư nếu bị rò rỉ.
Bộ điều khiển PLC Siemens S7-1200	Kỹ thuật viên vận hành nhà máy	Rất cao	A & I (Sẵn sàng & Toàn vẹn)	Điều khiển trực tiếp dây chuyền sản xuất 24/7.
Máy chủ SCADA & Màn hình HMI	Trưởng ca sản xuất / Quản trị viên OT	Rất cao	A & I (Sẵn sàng & Toàn vẹn)	Giao diện giám sát và phát lệnh điều khiển toàn nhà máy.
Dữ liệu vận hành (Historian Data)	Doanh nghiệp / Bộ phận QLCL	Cao	I & C (Toàn vẹn & Bảo mật)	Lưu trữ nhật ký sản xuất, thông số kỹ thuật phục vụ báo cáo.
Tường lửa pfSense (Gateway/DMZ)	Quản trị viên An ninh mạng (IT/OT)	Rất cao	A & I (Sẵn sàng & Toàn vẹn)	

1. **Hệ thống hóa lý thuyết & Chuẩn hóa tiêu chí:** Đã tổng hợp bài bản các bộ tiêu chuẩn an toàn thông tin quốc tế (NIST SP 800-82 Rev. 3, ISO/IEC 27001:2022, IEC 62443) để làm nền tảng đánh giá cho 5 tiêu chí bảo mật cốt lõi.
2. **Làm rõ sự khác biệt bản chất:** Phân tích chỉ ra rằng Consumer IoT ưu tiên hàng đầu cho **Tính bảo mật (Confidentiality)** nhằm bảo vệ dữ liệu riêng tư cá nhân. Trong khi đó, IIoT Công nghiệp đặt **Tính sẵn sàng (Availability)** và **An toàn vận hành (Safety)** lên tối thượng, đòi hỏi hệ thống duy trì liên tục 24/7.
3. **Triển khai thực nghiệm thành công:** Thiết lập mô hình ảo hóa Tường lửa pfSense kết hợp vùng đệm DMZ và hệ thống phát hiện xâm nhập Suricata IDS. Kết quả kiểm thử chứng minh khả năng cô lập hoàn toàn mạng điều khiển OT khỏi mạng văn phòng IT, ngăn chặn các hành vi thăm dò/quét công và giảm thiểu nguy cơ lây nhiễm mã độc.
4. **Xây dựng bộ công cụ quản trị rủi ro:** Đã lập Bảng ma trận rủi ro (Risk Register) phân lớp và bộ Checklist kiểm tra nhanh an toàn thông tin, hỗ trợ đặc lực cho công tác tự đánh giá bảo mật thực tế.

6.2. Môi đe dọa và lỗ hổng

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
01	Camera IP / Router	Tấn công Botnet (DDoS / Brute-force)	Mật khẩu mặc định (admin/admin), chưa đổi khi khởi tạo	Thiết bị bị chiếm quyền điều khiển, rò rỉ video riêng tư	NIST IR 8259A / OWASP IoT Top 10
02	Bộ điều khiển PLC	Chèn gói tin giả mạo (Man-in-the-Middle)	Giao thức Modbus TCP không mã hóa và không xác thực	Làm sai lệch thông số điều khiển, gây ngưng trệ dây chuyền	IEC 62443-4-2 (Section 5)
03	Máy chủ SCADA / HMI	Lây nhiễm mã độc độc hại (Ransomware)	Thiếu phân vùng mạng cô lập giữa văn	Mã hóa dữ liệu hệ thống, tê liệt hoạt	NIST SP 800-82 Rev. 3

			phòng IT và nhà máy OT	động sản xuất	
04	Web Dashboard DMZ	Quét cổng thăm dò & Khai thác dịch vụ	Các cổng dịch vụ HTTP/SSH mở công khai không giới hạn IP	Hacker tìm ra điểm yếu để leo thang đặc quyền vào mạng nội bộ	<i>Suricata Alerts Log / Nmap Scan</i>
T-05	Hệ thống SCADA cũ	Khai thác lỗ hổng thực thi mã từ xa (RCE)	Hệ điều hành Windows 7/XP cũ hết hạn, chưa cài bản vá	Bị kiểm soát toàn bộ máy chủ giám sát SCADA	<i>CVE Details / NIST SP 800-82</i>
T-06	Mạng Wi-Fi Smart Home	Nghe lén gói tin truyền thông (Eavesdropping)	Sử dụng chuẩn WPA2-Personal yếu hoặc giao thức HTTP unencrypted	Lộ thông tin tài khoản đăng nhập và dữ liệu di động	<i>ISO/IEC 27001 Control A.8.24</i>

Mặc dù đạt được các kết quả tích cực, nghiên cứu vẫn tồn tại một số hạn chế nhất định do điều kiện kỹ thuật và thời gian:

1. **Môi trường thử nghiệm dừng ở mức mô phỏng:** Các thử nghiệm mới được thực thi trên môi trường ảo hóa (VMware Workstation), chưa được đầu nối và kiểm thử trực tiếp trên các phần cứng PLC, cảm biến công nghiệp hay trạm HMI thực tế.
2. **Chưa bao phủ toàn bộ giao thức công nghiệp:** Hệ thống Suricata IDS mới tập trung phân tích và giám sát chính trên giao thức Modbus TCP, chưa mở rộng kiểm thử chuyên sâu cho các giao thức công nghiệp phổ biến khác như Profinet, OPC UA hay EtherNet/IP.
3. **Thiếu đánh giá tải thực tế:** Chưa thực hiện kiểm thử hiệu năng (Stress test) để đo lường độ trễ gói tin (Latency) của Tường lửa pfSense khi chịu lưu lượng mạng công nghiệp mật độ cao.

6.3. Hướng phát triển

Từ những kết quả và hạn chế nêu trên, các hướng phát triển tiếp theo của đề tài bao gồm:

1. **Triển khai trên mô hình Phần cứng thực tế (Physical Lab):** Tích hợp Tường lửa pfSense/Hardware Security Appliance vào mô hình nhà máy ảo với các bộ điều khiển PLC Siemens S7-1200 và cảm biến thực để đánh giá chính xác độ trễ thời gian thực.
2. **Mở rộng bộ luật phát hiện xâm nhập (IDS Ruleset):** Cập nhật và tối ưu hóa các bộ luật Suricata/Snort chuyên biệt cho chuỗi giao thức công nghiệp nâng cao (Profinet, OPC UA, DNP3).
3. **Tích hợp giải pháp AI/Machine Learning trong giám sát:** Nghiên cứu áp dụng các thuật toán Học máy để phát hiện các bất thường lưu lượng mạng OT (Anomaly Detection) thay vì chỉ dựa vào các bộ luật nhận dạng hành vi cố định (Signature-based).
4. **Xây dựng quy trình ứng cứu sự cố tự động (SOAR):** Kết hợp Tường lửa pfSense với các hệ thống quản lý sự kiện an ninh (SIEM/SOAR) để tự động hóa việc cô lập các IP/trạm máy bị nhiễm mã độc ngay khi phát hiện cảnh báo.

TÀI LIỆU THAM KHẢO

[1] Rubicon Communications, LLC (Netgate). *pfSense Certified Firewall & Router Official Documentation*. URL: <https://docs.netgate.com/pfsense/en/latest/>. Version: 2.7.x. Truy cập ngày 20/04/2026. Sử dụng: Hướng dẫn cấu hình hệ thống Tường lửa, phân vùng mạng DMZ, thiết lập Firewall Rules và NAT.

[2] OISF (Open Information Security Foundation). *Suricata User Guide and Open Source Engine (GitHub Repository)*. URL: <https://github.com/OISF/suricata>. Version: Tag v7.0.x / Branch main. Truy cập ngày 22/04/2026. Sử dụng: Triển khai gói giám sát phát hiện xâm nhập Suricata IDS/IPS trên pfSense và cấu hình bộ luật phát hiện hành vi quét cổng Nmap.

[3] National Institute of Standards and Technology (NIST). *NIST Special Publication 800-82 Revision 3: Guide to Operational Technology (OT) Security*. Washington, D.C.: U.S. Department of Commerce. URL: <https://csrc.nist.gov/pubs/sp/800/82/r3/final>.

Version: Revision 3 (2023). Truy cập ngày 15/04/2026. Sử dụng: Khung lý thuyết phân vùng mạng IT/OT, đánh giá rủi ro an toàn thông tin hệ thống điều khiển công nghiệp.

[4] International Organization for Standardization. *ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Geneva: ISO. URL: <https://www.iso.org/standard/27001>. Version: 2022 Edition. Truy cập ngày 18/04/2026. Sử dụng: Xây dựng tiêu chuẩn đánh giá an toàn thông tin và bộ Checklist kiểm tra các biện pháp kiểm soát an ninh (Controls A.8.5, A.8.24).

[5] International Electrotechnical Commission. *IEC 62443-3-3: Industrial communication networks - Network and system security - System security requirements and security levels*. Geneva: IEC. URL: <https://webstore.iec.ch/publication/7030>. Version: Edition 2.0. Truy cập ngày 19/04/2026. Sử dụng: Chuẩn chiếu mô hình phân vùng an ninh Zone & Conduit cho mạng IIoT/OT.

[6] OWASP Foundation. *OWASP Internet of Things (IoT) Top 10 Security Risks*. URL: <https://owasp.org/www-project-top-ten-iot/>. Version: 2023 Update. Truy cập ngày 10/04/2026. Sử dụng: Danh mục phân tích các lỗ hổng bảo mật và mối đe dọa phổ biến trên thiết bị IoT tiêu dùng.